Week 6 – Policies & Best Practices

1.Security Policies & Standards (ISO, NIST, GDPR)

What is a Security Policy?

A Security Policy is a formal document that defines how an organization protects its information, IT assets, and people from security threats.

It sets:

- Rules for acceptable use
- Roles & responsibilities
- Controls to reduce risk
- Procedures for response

Think of it like a “rulebook” for keeping data safe.

Why Security Policies are Important

- Ensures consistency in handling security.
- Helps with compliance (legal & regulatory).
- Defines clear responsibilities for employees.
- Supports incident response and audits.

- Protects data confidentiality, integrity, and availability (CIA triad).

2. Major Security Standards and Frameworks

Standard / Framework	Full Form	Focus	Real-Life Example
ISO 27001	International Organization for Standardization – Information Security Management System	Global standard for managing information security (policies, risk, compliance).	Companies like *IBM, Infosys, TCS* are ISO 27001 certified.
NIST CSF	National Institute of Standards and Technology – Cybersecurity Framework	U.S.-based framework focusing on 5 functions: *Identify, Protect, Detect, Respond, Recover.*	Used by *banks and government agencies* for cyber risk management.
GDPR	General Data Protection Regulation (EU Law)	Data privacy and protection for personal information.	*Google, Facebook* fined for GDPR violations due to user data misuse.
HIPAA	Health Insurance Portability and Accountability Act	Protects patient data in healthcare.	*Hospitals and clinics* encrypt and secure patient records.

PCI-DSS	Payment Card Industry Data Security Standard	Protects cardholder data for merchants and payment processors.	*Amazon, Paytm, Razorpay* must follow PCI-DSS.

Real-Life Example

- **Example:** A hospital using ISO 27001 policies defines:
    - *Access Control Policy* (only doctors can view patient records)
    - *Password Policy* (change every 90 days)
    - *Backup Policy* (daily automatic backup to cloud)
    - *Incident Response Policy* (report within 1 hour)
      → This helps the hospital stay compliant with HIPAA.

2. User Awareness Training-(Safe browsing, email security, and insider threats)

Why Awareness Matters

Most cyberattacks start with human error — phishing clicks, weak passwords, or unsafe downloads.
Training employees reduces risk significantly.

Safe Browsing Practices

Practice	Explanation	Example
Use HTTPS websites	Ensures data encryption	https://bank.com (secure) vs http://bank.com
Avoid downloading unknown software	Prevents malware	Don’t install random “free” games or extensions
Verify URLs before login	Prevents phishing	Fake site: g00gle.com
Keep browser & OS updated	Fixes vulnerabilities	Chrome updates patch exploits
Don’t use public Wi-Fi for sensitive work	Prevents MITM attacks	Use VPN if needed

Email Security

Tip	Example
Don’t click links in unexpected emails	Phishing: “Verify your account in 24 hours”
Check sender’s domain	hr@micros0ft-support.com
Avoid opening unknown attachments	.exe, .scr, .zip often malicious
Report suspicious emails	Forward to IT security team
Use spam filters and 2FA	Adds layered protection

Insider Threats

- Employees accidentally or intentionally leaking information.
- Example: USB data theft, screenshot sharing, credential misuse.
- Control measures:
    - Role-based access control (RBAC)
    - Logging & monitoring
    - Awareness + periodic reminders

3. Backup, Recovery, and Incident Response

Backup

Definition: Making a copy of important data to restore in case of data loss.

Simple Example:

You keep a copy of your college project on Google Drive — that's a *backup!*

If your laptop fails, you still have a copy.

Types of Backup:

Type	Description	Example
Full Backup	Copies all files each time	Sunday full system backup
Incremental Backup	Copies changes since last backup	Mon–Sat changes only
Differential Backup	Copies changes since last full backup	Wednesday → Sunday
Cloud Backup	Uploads data to secure cloud storage	Google Drive, AWS S3
Offline Backup	Stored on external drive / tape	Air-gapped backup for ransomware recovery

Backup Best Practices

- Use **3-2-1 rule**:
- **3** copies of data, on **2** media types, **1** offsite copy.
- Encrypt backups.
- Automate and test restoration.
- Label and document all backup jobs.
- Store backups in a different location (fire/flood safety).

```
# Create data folder and file
mkdir ~/data && echo "Student records" > ~/data/students.txt

# Create backup folder
mkdir ~/backup

# Take backup
cp -r ~/data ~/backup/

# Verify backup
ls ~/backup/data
```

Recovery

- The process of restoring systems or files from backup.
- Involves **testing** (periodically restoring sample files).
- Example: After ransomware attack, restore last clean backup from cloud.

steps in Recovery Process

Step	Description	Example
1 **Identify issue**	Detect data loss / corruption	Server stops responding
2 **Locate backup**	Find latest safe copy	Backup from yesterday
3 **Restore data**	Copy data back to system	`cp ~/backup/data ~/`
4 **Verify integrity**	Check that files work correctly	Open files, check logs
5 **Resume operations**	Users access data again	Website runs normally

Recovery Types

Type	Description	Example
Cold Recovery	Restore from offline backup (takes time)	Restore files from USB drive
Warm Recovery	Some systems ready, data partially loaded	Cloud VM with last week's data
Hot Recovery	Instant failover to live standby system	Bank DR server active 24/7

```
rm ~/data/students.txt

cp ~/backup/data/students.txt ~/data/

cat ~/data/students.txt
```

Real-Life Recovery Example

Example – Maersk Shipping (2017):
Maersk was hit by the *NotPetya* ransomware and lost access to 45,000 PCs.

Every backup and system was destroyed — except *one backup server in Ghana*.
Using that single backup, Maersk recovered its global operations in **10 days**.

Lesson: Even one clean backup can save billions.

Incident Response (IR)

Definition: A structured approach to handle a security breach.

Phase	Action	Example
1. Preparation	Create IR plan, assign team	IR Team: IT, HR, Legal
2. Identification	Detect incident	Unusual login, alert, or ransomware note
3. Containment	Stop the attack spread	Disconnect infected PCs
4. Eradication	Remove malware / fix vulnerability	Patch exploited software
5. Recovery	Restore data & monitor	Restore backups, re-enable access
6. Lessons Learned	Improve policy / awareness	Update training content

Real-life Example:

- *Maersk Shipping (2017)* lost 45,000 PCs to NotPetya ransomware but recovered within 10 days using **one surviving backup server in Ghana** → perfect backup policy!

Example 1: Target Data Breach (2013)
Attackers accessed Target's customer data via a 3rd-party HVAC vendor.

- IR Team contained by disabling vendor access.
- 40 million cards compromised, but IR reduced further exposure.
- Post-incident: improved vendor access policy.

Example 2: College Network Malware

- Students' systems infected with worm spreading via USBs.
- IT identified and isolated lab machines.
- Wiped infected drives and restored OS images.
- Updated antivirus & trained students on safe USB usage.

Tools Used in IR

- **Wireshark / Zeek** → Network packet analysis
- **Splunk / ELK Stack** → Log analysis
- **Nmap / Nessus** → Vulnerability scanning
- **FTK / Autopsy** → Forensic investigation
- **Backup utilities** → Restore clean systems
- **Ticketing tools** → Track IR workflow

Risk Management Basics

Definition

Risk Management is the process of identifying, analyzing, and reducing security risks to an acceptable level.

In short:

> “It’s about finding what can go wrong and preparing before it happens.”

Why It’s Important

- Prevents financial and data loss.
- Helps prioritize which risks are most serious.
- Guides how to allocate security budgets.
- Ensures compliance with standards (ISO 27001, NIST).
- Builds trust among customers and partners.

Key Steps in Risk Management

Step	Explanation	Example
1. Identify Assets	What are we protecting?	Laptops, databases, cloud data
2. Identify Threats	What can go wrong?	Phishing, insider theft, malware

3. Identify Vulnerabilities	What weaknesses exist?	Unpatched OS, weak passwords
4. Assess Risk	Combine impact + likelihood	Ransomware = High risk
5. Mitigate	Reduce risk using controls	Patching, firewalls, training
6. Monitor & Review	Continuous improvement	Quarterly audits

Risk = Threat × Vulnerability × Impact

Example:

Weak password (vulnerability) + Phishing email (threat) = Compromised account (impact).

Types of Security Controls (for Mitigation)

Type	Purpose	Example
Preventive	Stop incidents before they happen	Firewalls, access control, encryption
Detective	Find incidents after they happen	IDS, SIEM logs, CCTV monitoring
Corrective	Fix damage and restore systems	Backups, recovery plans, antivirus cleanup

Real-Life Example

- A college identifies risk: “Student records may be stolen via phishing.”
- Controls:
    - Training: no click policy
    - MFA for admin logins
    - Regular vulnerability scans
    - Incident response checklist

Ethics and Legal Aspects in Cybersecurity

What is Cyber Ethics?

Cyber ethics means using technology responsibly — respecting privacy, protecting information, and following laws.

Think of it as:

“Doing the right thing even when no one is watching.”

Why Ethics Matter

- Security professionals have access to sensitive data.
- Misuse of this power (e.g., hacking, leaking info) can cause legal and personal harm.
- Ethics build **trust** — essential for security careers.

Principles of Cyber Ethics

Principle	Meaning	Example
Confidentiality	Keep others' data private	Don't share classmates' info without consent.
Integrity	Don't alter or falsify data	Don't change marks or records.
Availability	Ensure systems are accessible ethically	Don't perform DoS on servers.
Honesty	Use hacking tools only with permission	Ethical hacking = allowed, illegal hacking = crime.
Responsibility	Think before posting/sharing online	Avoid spreading malware or fake news.

Types of Hackers (Based on Ethics)

Type	Behavior	Legal Status	Example

White Hat	Authorized ethical hackers	Legal	Security testers, bug bounty hunters
Black Hat	Unauthorized attackers	Illegal	Hackers stealing data
Gray Hat	Unapproved but not malicious	Borderline	Finds flaws, but discloses improperly

Cyber Laws (India Focus)

Law / Section	Description	Example
IT Act 2000	Governs cybercrimes, digital signatures, data privacy.	Unauthorized access = offense under Sec. 66.
Section 43A	Penalty for failure to protect sensitive data.	Company leak = compensation required.
Section 66C/D	Punishment for identity theft or cheating online.	Using fake email or impersonation.

Section 67	Ban on publishing obscene material online.	Sharing explicit content = punishable.
Digital Personal Data Protection Act (DPDPA) 2023	Protects personal data and gives privacy rights to users.	Company fined for sharing user data without consent.

Global Cyber Laws

Law	Country/Region	Purpose
GDPR (2018)	European Union	Protects personal data and privacy.
HIPAA	USA	Protects patient medical data.
CCPA	California, USA	Gives consumers data control rights.
NIST Framework	USA	Provides risk management guidelines.

Real-World Ethical Scenarios

Situation	Ethical Action
You find a vulnerability in your college website.	Report it to admin — don’t exploit it.
You receive a friend’s password accidentally.	Delete it; inform them to change it.
Your friend shares pirated software.	Refuse to install — it’s illegal and insecure.
You’re learning hacking tools in Kali Linux.	Use only in test environments or with written permission.

Responsibilities of Cybersecurity Professionals

- Maintain confidentiality of data.
- Follow organizational and legal policies.
- Report vulnerabilities responsibly.
- Never access systems without explicit permission.
- Stay updated on laws and compliance requirements.

Real-Life Example: Legal Case

In 2020, a cybersecurity researcher tested airline websites without permission and reported the bug publicly. Although he meant well, the company filed a case under IT Act 66C (unauthorized access).
Lesson: Always get written authorization before testing systems.

6.**Practical Activities**

1. Draft a Basic IT Security Policy (for a small business)

Example scenario:

Business: “ABC Designs Pvt Ltd” (20 employees, uses email, laptops, cloud storage, Wi-Fi)

Step-by-step template:

Section	What to include	Example
Purpose	Define why policy exists	“To protect company data and maintain business continuity.”
Scope	Who & what it covers	“All employees, contractors, systems, and devices.”
Roles & Responsibilities	Assign duties	“IT admin: maintain firewall; Users: strong passwords.”
Acceptable Use Policy	What users can/cannot do	“No installing unauthorized software.”

Password Policy	Strength & rotation	“Min. 8 chars, mix of upper/lower/symbol, change every 90 days.”
Data Protection	Storage, encryption	“All sensitive files encrypted using AES-256.”
Backup Policy	Schedule & testing	“Weekly cloud backup, monthly restore test.”
Incident Response Plan	How to handle incidents	“Report within 1 hour to IT team.”
Access Control Policy	Who can access what	“Only HR can access payroll files.”
Compliance & Review	Audits and updates	“Review every 6 months.”

Deliverable: Each student/team writes a 1–2 page IT Security Policy document.

2. Simulate Backup & Restore of Files

On Kali / Linux / Windows demo:

```
# Create a sample data directory
mkdir ~/data && echo "Important project file" > ~/data/project.txt

# Create a backup directory
mkdir ~/backup
```

```
# Copy files to backup
cp -r ~/data/* ~/backup/

# Verify backup
ls ~/backup

# Simulate accidental deletion
rm ~/data/project.txt

# Restore from backup
cp ~/backup/project.txt ~/data/

# Verify restoration
cat ~/data/project.txt
```

Windows PowerShell:

```
Copy-Item C:\Data\* C:\Backup\ -Recurse
Remove-Item C:\Data\project.txt
Copy-Item C:\Backup\project.txt C:\Data\
```

Explain:
Backups protect against ransomware, accidental deletion, or hardware failure.

Bonus demo: compress & encrypt backup

```
tar -czf backup.tar.gz ~/data
```

```
gpg -c backup.tar.gz  # prompts for password
```

Summary / Takeaways

Topic	Key Idea
Policies & Standards	Set formal rules for secure operations (ISO, NIST, GDPR).
User Awareness	Educate users – human error is biggest risk.
Backup & Recovery	3-2-1 rule + regular restore tests.
Incident Response	Identify → Contain → Eradicate → Recover → Learn.
Risk Management	Identify, analyze, mitigate, monitor.
Ethics & Law	Follow IT Act, GDPR, and ethical hacking principles.
Practical Skills	Write a security policy + perform a file backup/restore.